Security Agent Design Studio

Objective

Design a small, defensible agent workflow for your assigned security scenario. Your team will decide what the agent does, which tools it uses, where a human intervenes, and how to check the result.

Overview

Open your team's Google Docs tab and complete the five numbered responses in its worksheet. You can do this on paper or in the document.

This is a design exercise. No coding, tool installation, or live security actions are required. Feel free to research the topic if anything about the scenario is unclear. The tool menu for each scenario describes hypothetical capabilities, use those as a guide, but you do not have to use any or all the tools.

If you make any assumptions about the scenarios or tools, make sure you state them briefly.

Steps

1. **System contract:** State the task in one sentence. Identify the input and the output format with its key fields.
2. **Workflow and human role:** Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.
3. **Essential tools:** Choose only the essential tools for the task. For each, specify input → output and what happens on failure.
4. **Failure walkthrough and trace:** Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits). How would you measure/audit it?
5. **Success test:** Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Keep the design small

Choose only the necessary tools make sure each tool is justified. Other capabilities can be deferred. Logging, validation, and approval checks may be host controls rather than separate tools. A single agent is sufficient.

Use one of the orchestration patterns discussed last week (e.g. chaining, routing, parallelization, orchestrator–workers, evaluator–optimizer). Mark each workflow step as LLM, deterministic code, or human. Give a brief reason for the pattern and interface choices.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the control that prevents or catches it. No slides are required.

Submission and Grading

Keep your completed worksheet and submit with the next assignment.

There is no separate submission due at the end of class.

Note: Include this with the next assignment

Each student should include a copy of your team's completed worksheet for your next assignment submission, labeled "Week 3 Design Studio." Include the scenario and all team members' names.

Note: Teammate submissions can be identical for all members of the team.

Copy your team's completed response into the submission, or attach an export containing only your team's work. The remaining assignment components account for 80 points.

Rubric

Response	Weight	Full credit evidence
1 System contract	20%	A one-sentence task, concrete input, and useful output with a stated format and key fields. Briefly stated assumptions where needed.
2 Workflow	20%	A system diagram labeling LLM, code, tools, and humans. A justified design pattern, with actions requiring approval and their triggers identified.
3 Tool choices	20%	Only necessary tools, each justified with its input, output, and failure behavior. A brief reason for the direct-tool or MCP interface choice.
4 Failure and trace	20%	A specific failure walkthrough with an enforceable control, retry or stop limits, and trace fields that would show how the system handles it.
5 Success test	20%	One metric and proposed target, with a small test set that includes the failure case. A clear source for the expected answers.
Total	100%	

Before you submit

- ☐ All five responses are complete, with names and scenario identified.
- ☐ The design honors the scenario's time, cost, data, and approval constraints.
- ☐ Tool failures and uncertain results have an explicit response or stop condition.
- ☐ The success target is labeled as proposed; no invented test results are presented.
- ☐ The submitted copy is readable and contains only your team's work.

Scenarios

- Click on the team number assigned in class and follow the scenario listed.

Phishing Triage

Scenario brief | Read this page, then complete the worksheet

Scenario

The SOC at a large research university receives about 200 user-reported emails per day through the mail client's report button. Three analysts share triage duty alongside everything else. Most reports are bulk marketing or harmless spam. A handful each week are credential phishing, and a few times a semester (although now becoming more frequent) a targeted spearphish arrives aimed at research faculty. Design an agent system that triages every report, answers the reporter, and escalates real threats to an analyst with the evidence already assembled.

Key Stakeholder

SOC manager.

Design Scope

Design the path for one reported email, from intake to a reporter reply and an analyst escalation when needed.

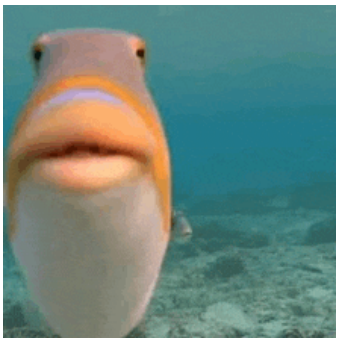
Example of available tools

Tool	Input → output
Email parser	raw .eml file → structured headers, URLs, attachments, sender history
URL reputation lookup	URL → verdict, category, domain age
Attachment sandbox	file → behavioral report (about 5 minutes per run; each run costs money)
Directory lookup	username → department, role, VIP flag
Mailbox search	message fingerprint → other recipients across the org
Quarantine action	message ID + mailbox → message removed (requires approval)
Reply sender	reporter + template + variables → acknowledgment or verdict email
Ticket creation	summary + evidence → SOC case

Constraints to preserve

- Reporters expect an answer within 30 minutes.
- Sandbox runs cost money; detonating every attachment is not an option.
- Removing mail from other users' mailboxes requires human approval.

Worksheet Team 1



Team Number: **1**

Team Scenario Title: **Phishing Triage**

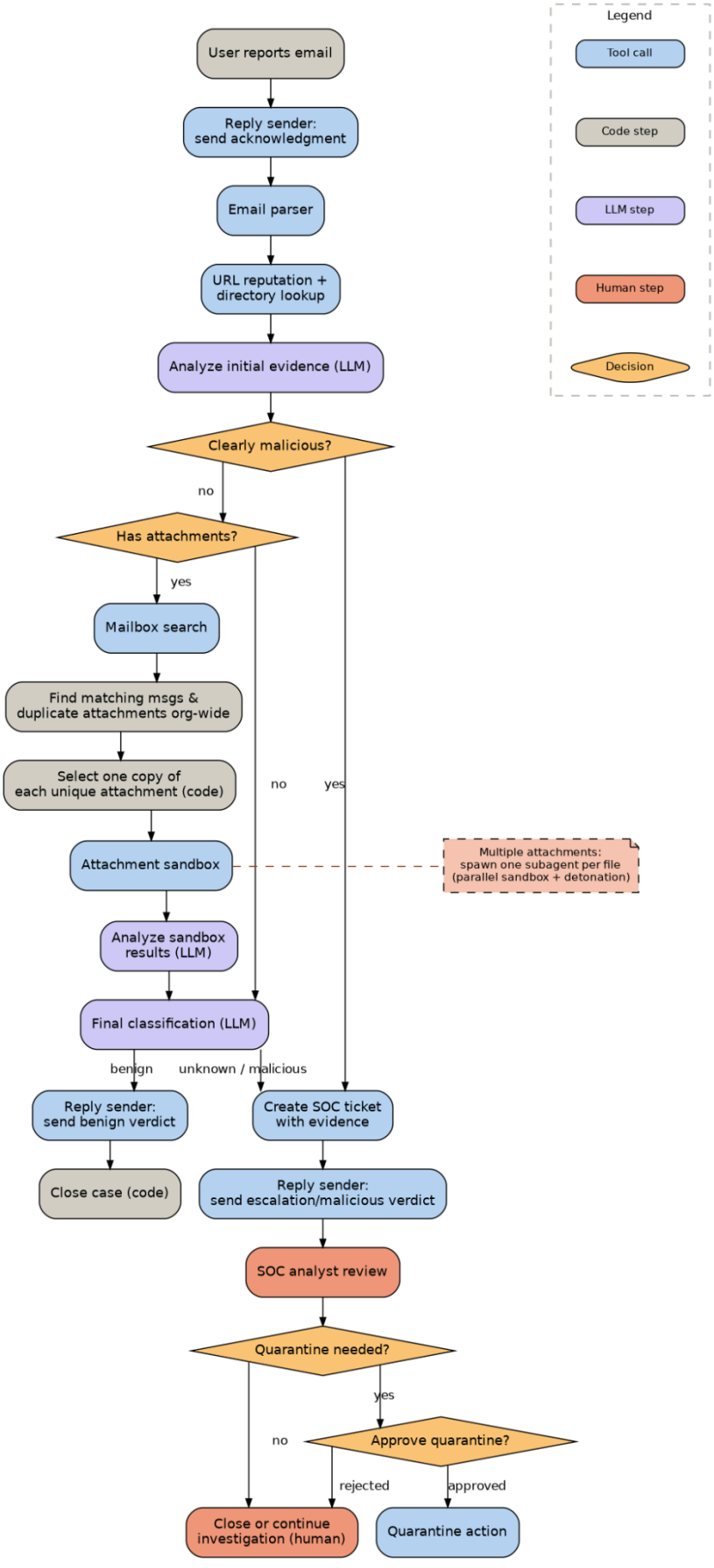
Team members: **David Jiang, Ryan Banko, Alex Mages, Theo Prosise**

1. System contract

Classify phishing email reports as malicious, benign, or escalate; upon an escalation or malicious result, package evidence and provide it to the analyst.

- Input: user reported email (.eml) file
- Output: Classification as Benign / Malicious / Unknown. Malicious and Unknown escalated to analysts with evidence for further investigation.
- Assumptions: System only processes user-reported emails, and actions past classification handled by analysts.

2. Workflow and human role



We chose a prompt chaining design because the process of determining whether or not an email is malicious or not consists of known dependent stages that does not require much agentic deliberation on knowing what the next step is. We decided to against using a parallelization because although parallelization may allow additional agentic decision making to better determine if an email is safe and reduce further tickets sent to the SOC, the SOC team only receives 200 tickets a day and prompt chaining will already reduce many of the tickets while being a cheaper alternative to parallelization.

The action that requires approval is the tool call to quarantine the email. This requires approval from the SOC analyst, after receiving the knowledge that the agentic system classified the report as malign and had given the analyst the relevant evidence. If the analyst's expertise and the provided evidence cause him to believe that the mail requires quarantine, he will trigger that action.

3. **Select Tools**

Tool	Input → output	Justification	Failure
Email parser	raw .eml file → structured headers, URLs, attachments, sender history	Need to convert email file into structured data for the rest of the workflow	Try again at most 2 times. If failure on all attempts, then create a ticket and escalate to SOC.
URL reputation lookup	URL → verdict, category, domain age	Unsafe URLs means the email is very likely to be a phishing attempt	Try again at most 2 times. If failure on all attempts, then create a ticket and escalate to SOC.
Attachment sandbox	file → behavioral report (about 5 minutes per run; each run costs money)	Unsafe attachments means the email is very likely to be a phishing attempt	If failure, then create a ticket and escalate to SOC.
Directory lookup	username → department, role, VIP flag	Higher level employees and research faculty are more likely to be targeted	Try again at most 2 times. If failure on all attempts, then create a ticket and escalate to SOC.
Mailbox search	message fingerprint → other recipients across the org	Prevents unnecessary resources being allocated to tasks that have already been run	Try again at most 2 times. If failure on all attempts, then create a ticket and escalate to SOC.
Quarantine action	message ID + mailbox → message removed (requires approval)	Allows malicious mail to be handled by agent after analyst approval	Try again once. If failure again, create an alert and pause.
Reply sender	reporter + template + variables → acknowledgment or verdict email	Automates communication back to reporter	Try again once. If failure again, create an alert and pause.
Ticket creation	summary + evidence → SOC case	Automates and standardizes reporting and evidence delivery to analyst	Try again once. If failure again, create an alert and pause.

4. **Failure walkthrough and trace**

Specific failure scenario: A reported email contains a suspicious attachment, but the attachment sandbox times out and does not return a behavioral report.

- System response: The system retries the sandbox tool once. If it fails again, it stops retrying because each sandbox run takes time and money. The agent will assume the attachment may be unsafe, classify the result as unknown and create a SOC ticket containing the evidence already collected (while noting that the sandbox result is missing). The email is then escalated to an analyst for review.
- Trace/audit fields: The system logs the case number, timestamp, tool failure, evidence collected, classification, output.

5. **Success Metrics**

We would have a small test set of prior emails that have been classified by analysts. This will include examples in which attachments are known to fail the sandbox test. Our goal metrics are accuracy and false negatives, and we would rather have lower accuracy if that means catching all valid reports (ex: escalating an email with a likely safe attachment if it fails the sandbox). Thus, our targets would be 90% accuracy and 0% false negatives to balance these concerns.

Success Metric: Our proposed metric is malicious-email recall (avoiding false negatives), with a target of at least 98%. We would use a small test set of prior user-reported emails with final classifications supplied by SOC analysts. The set includes examples where attachments are known to cause sandbox failures. For those cases, the expected outcome is escalation to an analyst rather than a benign classification, even if the available evidence otherwise appears safe.

Keep your completed worksheet and submit with the next assignment.

Alert Prioritization

Scenario brief | Read this page, then complete the worksheet

Scenario

A managed security service provider watches 40 client environments. The shared SIEM produces roughly 35,000 alerts per day; tier-1 analysts can properly investigate about 300. Alerts arrive with a rule name, a timestamp, and a handful of raw fields. Design an agent system that enriches each alert and produces a ranked queue with a written rationale an analyst can audit before acting.

Key Stakeholder:

Tier-1 team lead.

Design Scope

Design enrichment and ranking for one incoming alert in one client environment. Show how its evidence and rationale enter the queue; you do not need to design the entire SIEM.

Example of available tools

Tool	Input → output
SIEM query	alert ID → underlying raw events
EDR host lookup	hostname → process tree, recent detections, agent health
Threat intel lookup	IOC → reputation, associated campaigns
Asset inventory	host → owner, criticality, internet exposure
Identity context	account → role, recent auth anomalies, MFA status
Case management API	alert + enrichment + disposition → case created or updated

Constraints to preserve

- Fixed enrichment budget per alert (API calls and tokens).
- Strict per-client data isolation; nothing from one client may enter another client's context.
- The queue must reflect a new alert within 5 minutes of arrival.
- Every rank needs a written rationale; “the model said so” does not survive audit.

Team 2 Worksheet

Alert Enrichment and Prioritization

Class or section: [enter] Team members:

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: An enrichment result belongs to a different client than the incoming alert.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Worksheet {Template Only}

Copy this page and paste it in your teams section

Team Number: 2
Team Scenario Title:: Alert Prioritization
Team members: [Shweta Mittal, Atharva Ashish Jog, Jiaxiang Chen, Varun Bhanushali, yuhang sun]

Complete the following questions for your team's assigned scenario

6. System contract

State the task in one sentence. What does your system need to do? (This is not a trick question). Then identify the input and the output format with its key fields. If you are unfamiliar with the scenario feel free to research the topic.

Answer: The tier-1 analyst team can review up to 300 alerts per day, while the siem generates around 35000 alerts per day. The system needs to analyze and enrich incoming alerts, prioritize them based on risk, and provide a clear rationale so analysts can audit the highest-priority alerts first.

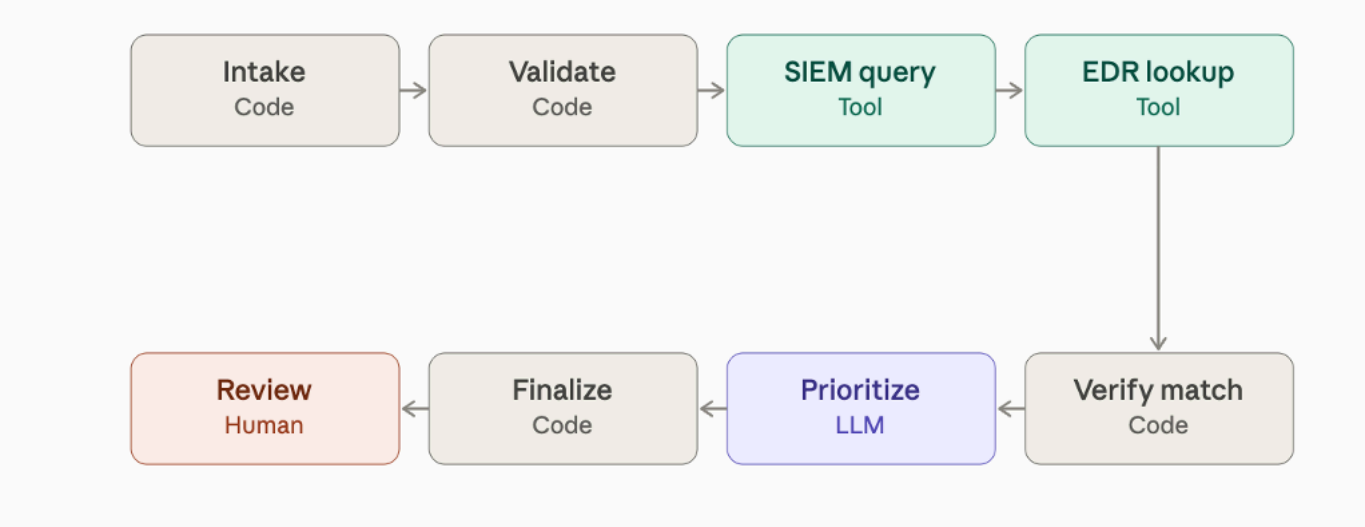
Input: Client ID, alert ID, rule name, timestamp,raw fields(original data values that came with the alert straight from the SIEM) , evidence(for the alert, i.e rationale for the classification).

Output format :JSON Fields: priority_score, evidence[] (tool, args, result, timestamp), client_id, run_id, alert ID,missing_enrichment[] , rationale as well as enhancing missing information and fields before presenting to the human.

7. Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.

A step by step approach would be:



1. Incoming alert (tag it with `client_id` and a `run_id`)
2. [Code] Validate client ID + start 5-minute deadline + extract indicators
3. [Tool] SIEM + host context enrichment
4. [Tool] Look up host/context
5. [Code] Verify returned data belongs to same client; enforce API/token budget
6. [LLM] Read alert + enrichment and THEN assign priority and write rationale
7. [Code] Validate output / add it to ranked queue
8. [Human] Analyst reviews rationale before taking action

Proposed processing cutoff: 270 seconds. If further work would exceed the API/token budget or this cutoff, stop and enqueue the alert as unresolved with a reason within five minutes of arrival.

Design pattern: Chaining, because the output of one task is being fed to the next task and stuff happens sequentially rather than parallely.

Human: Reviews the top 300 alerts. Also when there's conflicting evidence labelled by the agent and the code, then it's escalated for human review.

8. Select Tools

Choose only the essential tools for the task. For each, specify input → output and what happens on failure

1. SIEM Query:
    a. Input: alert ID,client_id
    b. Output: underlying raw security events.

* This is done because the original alert barely contains any information on what actually triggered it.

In case of failures: If query time runs out, retry once. If it still fails, mark the enrichment as incomplete and escalate it to the human reviewer.

2. EDR Host lookup:
    a. Input: hostname,client_id
    b. Output: process tree, recent detections, agent health

Interface: direct tools, because the workflow uses two fixed integrations and does not require dynamic discovery.

* This is done as this is a much stronger signal on whether the activity on the machine is actually suspicious or not.

In case of failures: If hostname is missing or EDR has no data, record "EDR unavailable" and continue with reduced confidence.

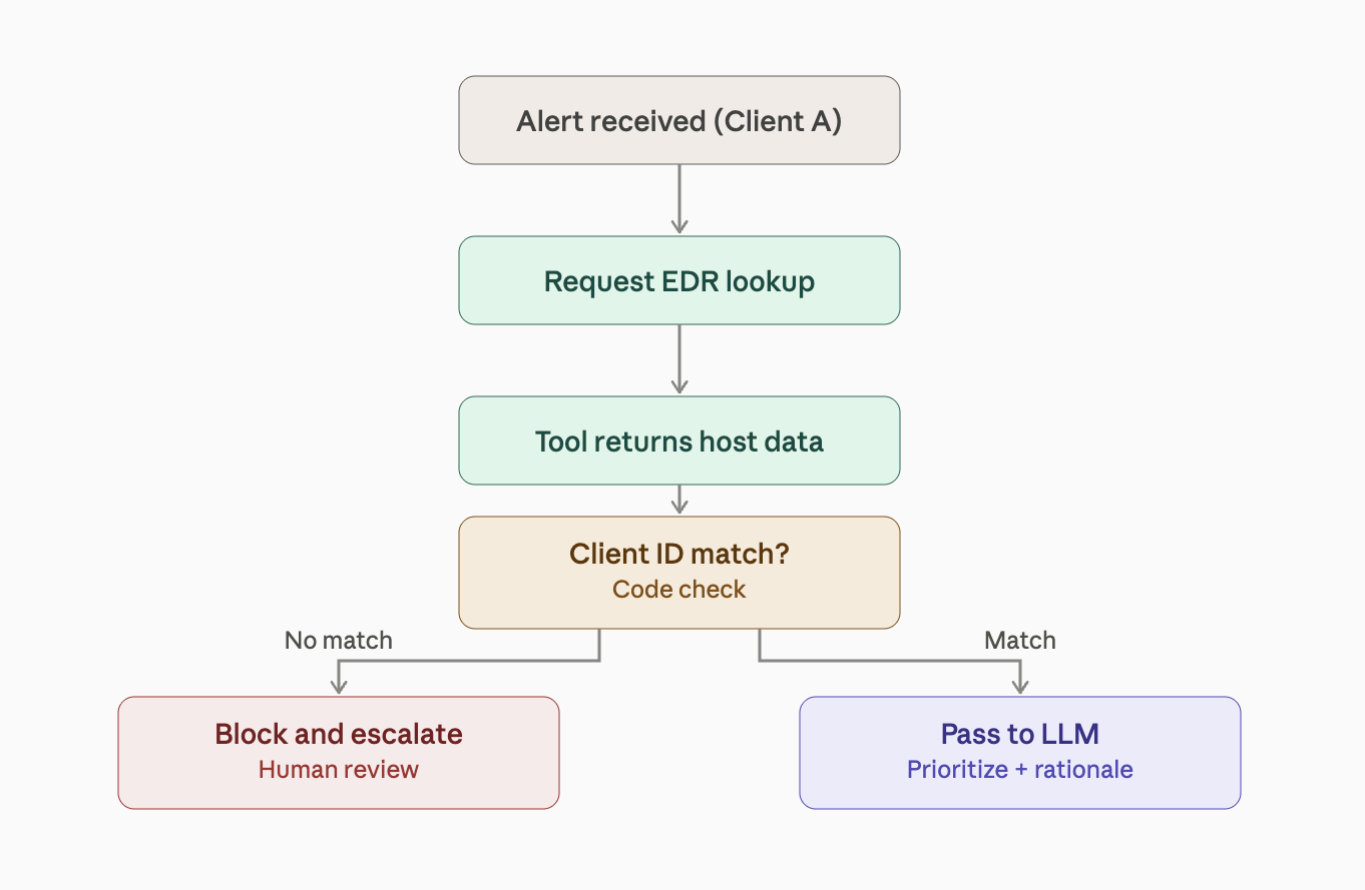
9. Failure walkthrough and trace

Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

One failure scenario that might happen is an enrichment result belonging to a different client than the incoming alert.

For example: An alert belongs to Client A. The agent calls the tool asking for EDR for HOST-123. Tool accidentally returns Client B's HOST-123. This is a serious data leak.

Guardrail: Every alert can have a client_id. Every tool call should also include that client. After data comes back, we compare and check the client_ids. (alert.client_id == enrichment.client_id ?). If no, then don’t give the faulty data to the LLM at all. On a client-ID mismatch, stop without retry and escalate. Log run_id, step_id, tool, expected_client_id, returned_client_id, timestamp, status, stop_reason, and final_action, without recording the other client's payload.



10. Success Metrics

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric: Priority agreement with expert analysts.

Proposed target: >= 90%

We first make a tiny test set comprising of 20 previously investigated alerts.

Then have the expert analysts independently assign the labels (high/medium/low priority).

In the failure case above (cross-client data leak), make sure that the answer returned/behaviour is “stop and escalate”. This way we can test both the classification accuracy as well failure modes.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.

Vulnerability Prioritization

Scenario brief | Read this page, then complete the worksheet

Scenario

A mid-size enterprise runs an authenticated vulnerability scan monthly. The latest export contains about 40,000 findings across 6,000 assets. The patching teams can realistically close about 500 findings a month. Design an agentic system that turns the export into a defensible patch plan: what gets fixed this month, what waits, and why.

Stakeholder: Director of IT operations.

Design Scope

Design the path for a small batch of scan findings, from normalization to proposed patch priorities. State how the path would respect the monthly capacity and handle an unpatchable asset.

Example of available tools

Tool	Input → output
Scan export reader	CSV export → normalized, deduplicated findings
NVD lookup	CVE ID → CVSS vector, description, references
CISA KEV lookup	CVE ID → listed or not, date added, due date
EPSS lookup	CVE ID → exploitation probability score
Asset database	asset → business criticality, internet exposure, owner, patchability
Ticketing	plan entry → patch task assigned to the owning team

Constraints to preserve

- KEV-listed findings carry a two-week internal remediation clock in this scenario; use that internal deadline in the plan.
- Scanner output contains duplicates and stale entries; trust it accordingly.
- Some assets cannot be patched; the plan must note compensating controls instead.
- Every inclusion and exclusion needs a one-line justification a system owner will read.

CYBERSEC 590: Design Studio Worksheet

Team Number: 3

Team Scenario Title: Vulnerability Prioritization

Team Members: Sean Rogers, Paul Prommark, Deekshitha Manjunatha Reddy, Jinghao You

1. System Contract

Task: State the task in one sentence. What does your system need to do? Identify the input and output format with key fields.

Task Statement: Turn the monthly ~40,000-finding vulnerability scan export into a defensible, capacity-bounded (≈500 findings) patch plan that states what gets fixed this month, what's deferred, and why.

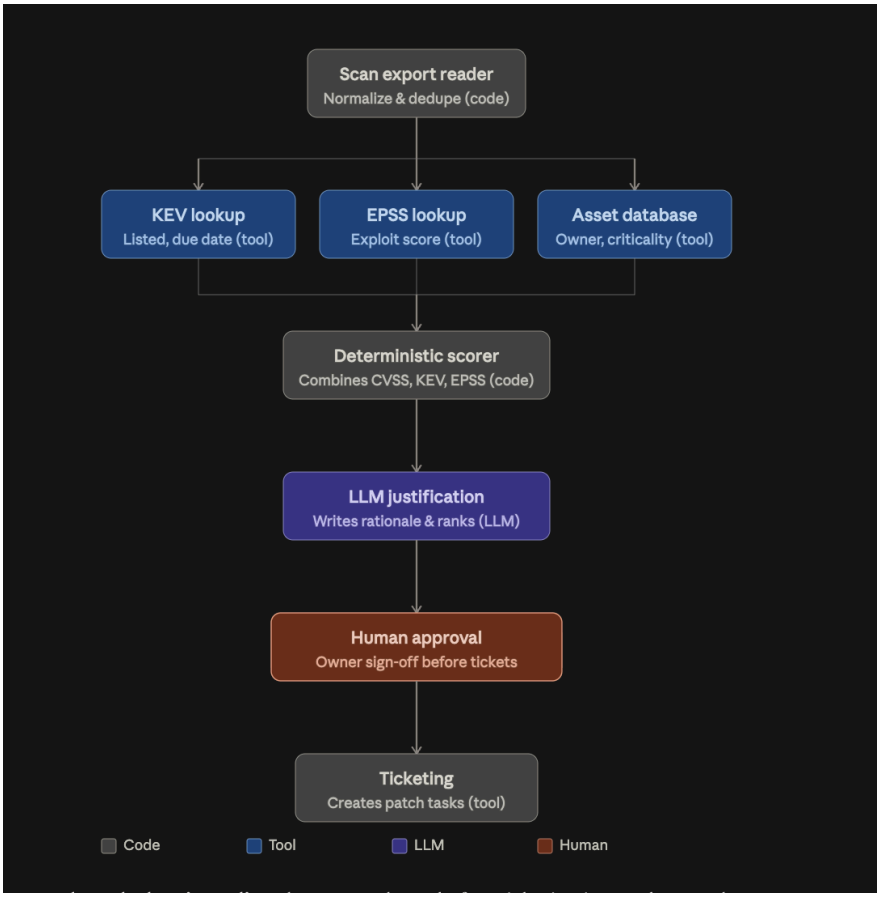
Input: Scan export CSV (finding ID, CVE ID, asset ID, CVSS, first-seen date, scan date).

Output Format / Key Fields: Ranked plan list (CSV/JSON), one row per deduplicated finding-cluster:

1. **finding_id**: Unique finding identifier
2. **cve_id(s)**: Associated CVE identifiers
3. **asset_id(s)**: Target asset identifiers
4. **business_criticality**: Asset criticality score/rating
5. **internet_exposure**: Exposure status
6. **cvss_score**: Severity score
7. **epss_score**: Exploitation probability score
8. **kev_status**: CISA KEV status (listed / not-listed / unknown)
9. **kev_internal_deadline**: Internal remediation deadline (date_added + 14 days, if KEV-listed)
10. **priority_score**: Overall computed priority
11. **decision**: Action disposition (patch-this-month / deferred / compensating-control / needs-manual-review)
12. **justification**: One-line rationale
13. **owning_team**: Responsible team or owner
14. **ticket_id**: Tracking ticket ID (once created)
15. **status**: Current workflow status

2. Workflow and Human Role

Task: Draw a system diagram showing agent design. Choose a design pattern and explain why. Label components (LLM, code, tools, humans) and identify approval triggers.



Human Role & Approval Triggers: The approval gate before ticketing is mandatory whenever the plan includes a KEV-listed exclusion, an unpatchable-asset compensating control, or the monthly plan reaches capacity. The LLM can rank and draft justifications, but nothing gets ticketed until the IT Ops Director/system owner signs off.

3. Selected Tools

Task: Choose essential tools. For each, specify input → output, necessity, and failure behavior.

Tool	Input → Output	Why Essential	On Failure
Scan Export Reader	CSV → Normalized, deduplicated findings	Raw export has duplicates/stale entries. Schema parsing must be deterministic and code-based, not LLM-guessed.	Malformed file/unreadable rows → Quarantine rows into an `unparsed_rows` report; stop and alert rather than guessing schema.
NVD Lookup	CVE ID → CVSS vector, description, references	Supplies severity signal and technical details for justification line generation.	Timeout/empty after 2 retries → Mark `cvss = unknown`; exclude from auto-selection and route to manual review.

Tool	Input → Output	Why Essential	On Failure
CISA KEV Lookup	CVE ID → Listed status, date added, due date	Drives the mandatory 14-day internal deadline constraint.	Timeout/empty after 2 retries → Mark `kev_status = unknown`; route to manual-review bucket regardless of other scores.
EPSS Lookup	CVE ID → Exploitation probability	Secondary signal to rank non-KEV, non-critical CVEs effectively.	Timeout/empty → Treat EPSS contribution as 0/unknown (non-blocking tie-breaker); log gap for audit.
Asset Database	Asset ID → Criticality, exposure, owner, patchability	Computes risk (criticality × exposure), routes tickets, and detects unpatchable assets.	Asset not found/lookup fails → Treat conservatively as high-priority/needs-revie w; require confirmed `patchability` value before generating compensating controls.
Ticketing System	Plan entry → Patch task assigned to owning team	Dispatches approved plan tasks to actioning teams.	Creation fails → Retry 3x with backoff; if still failing, mark `status = ticket_failed` and report for manual creation.

4. Failure Walkthrough and Trace

Task: Create a failure scenario (e.g., tool timeout, empty response, off-topic request) and describe how guardrails, retries, and stop limits handle it.

Failure Scenario: CISA KEV lookup times out for a batch of 200 findings mid-run.

Handling Process:

- **Retry with Backoff:** Retry lookup twice (~5s, then ~15s) to rule out minor network glitches.
- **Fail Safe, Not Silent:** If still failing, do not default to "not KEV". Mark as **"KEV status unconfirmed"** and route to manual review rather than auto-scoring.
- **Retry Cap:** Limit to 2 retries per finding to avoid stalling pipeline execution.
- **Audit Logging:** Log every failed lookup with affected CVE IDs, timestamp, and error details for auditing.
- **Threshold-Based Halt:** If over 5% of a batch has unresolved lookups, halt the pipeline and alert an operator.
- **Malformed / Off-Topic Input:** Caught by schema validation during ingestion and rejected immediately before pipeline execution.

Summary Guardrails: Fail-safe defaults (missing data = escalate), retry caps, threshold-based halts, and complete audit logging for enrichment failures and human overrides.

5. Success Metrics

Task: Choose one metric and a target. Describe a small test set, answer sources, and include the failure case above.

Metric & Target: Firstly**,** 100% coverage. Every single actively exploited vulnerability must have a documented action plan within two weeks—none can slip through the cracks or sit unanswered in a queue. Secondly, The automated system and the senior analyst must agree on at least 85% of the top 500 highest-priority items. This proves the tool doesn't just process alerts quickly, but prioritizes work like an experienced human would.

Test Set & Expected Answers: Held-out sample of 50 findings from past real exports, containing 5 KEV-listed CVEs (one on an unpatchable asset), duplicates/stale entries, and failure conditions. Ground truth expected answers are independently supplied by a senior security analyst's manual review.

Failure Case Included: 2–3 KEV findings in the test set simulate lookup timeouts. System must route these to **"KEV status unconfirmed → manual review"**. Misclassifying an unconfirmed KEV as "not listed" results in an automatic test failure regardless of overall score.

6. Report in 45 Seconds

Task: State your workflow and pattern choice, then identify the worst failure and mitigating control.

Workflow & Pattern: We used an **orchestrator–workers** pattern: deterministic code dedupes and normalizes the export, fans out parallel tool calls (NVD, KEV, EPSS, asset DB) per unique finding, a central scorer applies the 500-item capacity cap with KEV findings forced to the top and bound by their 14-day clock, the LLM only drafts grounded one-line justifications, and a human signs off on the plan plus any KEV-deferral, critical-unpatchable, or lookup-failure exceptions before tickets are cut.

Worst Failure & Mitigating Control: The worst failure is a CISA KEV lookup silently failing and an actively-exploited CVE being treated as "not KEV." To control for this, failure sets status to `unknown`, treating it as elevated risk that forces manual review and trips a batch-level stop if >5% of findings are affected.

Keep your completed worksheet and submit with the next assignment.

Threat Hunt

Scenario brief | Read this page, then complete the worksheet

Scenario

A sector ISAC bulletin reports an actor targeting higher-education research institutions: initial access with valid accounts, lateral movement over remote services, staging with archive utilities, and exfiltration over alternative protocols. Your organization has 90 days of searchable logs. No alert has fired. Design an agent system that plans and executes a hunt to confirm or deny the actor's presence, and documents the evidence either way.

Stakeholder

Head of detection and response. Accepts the design if the hunt's conclusion, positive or negative, is backed by evidence chains a second analyst can replay.

Design Scope

Choose one behavior from the bulletin and design a bounded hunt for it. Explain what a negative result would mean within the data and time window you searched.

Example of available tools

Tool	Input → output
SIEM query runner	query → result table (rate-limited; expensive at 90-day scope)
EDR telemetry search	process or network expression → matching events
Auth analytics	account + time window → anomaly score and outlier logins
ATT&CK data lookup	technique ID → data sources, detection notes
Netflow summary	host or subnet + window → top talkers, volumes, destinations
Report builder	structured findings → hunt report with evidence references

Constraints to preserve

- SIEM queries are rate-limited; broad 90-day queries must be justified before they run.
- Negative results must be recorded along with the exact queries that produced them.
- The hunt has one week of calendar time.
- Every claim in the final report needs a replayable evidence chain.

Team 5 Authorized Red Teaming

Scenario brief | Read this page, then complete the worksheet

Scenario

Your organization runs one external penetration test a year, and the report is stale within weeks. The security team wants a continuous check: an agent that repeatedly probes a scoped, authorized target (a staging web application and a lab subnet the team owns), attempts safe validation of weaknesses, and reports exploitable paths with evidence. Design the agent that plans an approach, acts against the target, observes results, and decides what to try next, all inside a hard authorization boundary.

Stakeholder

Offensive security lead who signed the rules of engagement. Accepts the design if the agent never leaves scope, never runs a destructive action, and produces findings another tester can reproduce.

Your 30 minute scope

Design one cycle of an authorized check, from validating a target to reporting evidence. Keep validation non-destructive and within the lab scope. This class activity involves no live probing.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
Scope validator	target → in-scope or refused (checks an allowlist of hosts and ranges)
Recon and scanner	in-scope host → open services, versions, surface
Safe validation runner	candidate weakness → non-destructive proof-of-exposure result
Credential checker	service → weak or default credential present, yes or no
Evidence capture	step → timestamped request, response, and artifact
Finding writer	confirmed weakness + evidence → report entry with remediation note

Constraints to preserve

- A hard scope boundary: any action against an out-of-scope target must be refused, not attempted.
- Destructive actions (data deletion, denial of service, persistence) are prohibited outright.
- A tool and step budget caps how far the agent runs before it must stop and report.
- Every action is logged so a human tester can reproduce and verify each finding.

Team 5 Worksheet

Continuous Automated Red Teaming (Authorized, Scoped)

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: A discovered target or redirect points outside the authorized allowlist.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Team 6 Incident Containment

Scenario brief | Read this page, then complete the worksheet

Scenario

EDR has flagged ransomware precursors at a manufacturing firm: shadow-copy deletion on two workstations and suspicious SMB fan-out from a server that also runs the shipping line's scheduling. The on-call responder has a 15-minute decision window. Design an agent system that assembles the picture, proposes containment, and executes approved actions quickly without breaking the business.

Stakeholder

Incident commander. Accepts the design if containment is fast, proportionate, and every action is logged and reversible where possible.

Your 30 minute scope

Focus on the decision to isolate the shipping scheduling server. Use the supplied incident facts as the starting input and show the evidence, approval, and rollback record needed for that decision.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
EDR host isolation	host → network-isolated (reversible, but disruptive while active)
AD account disable	account → disabled
Firewall block	IOC → blocked at egress
Blast-radius lookup	host → dependent systems, business function, downtime cost
Backup status check	host → last good backup, estimated restore time
Comms drafter	incident facts → stakeholder notification draft
Action log	every action → timestamped, attributable entry

Constraints to preserve

- Isolating the scheduling server stops the shipping line; that decision needs a named human approval.
- The decision window is 15 minutes; the agent must surface the hard choice, not bury it.
- Isolations and disabled accounts must be tracked for rollback.
- The after-action review will read the action log; completeness matters.

Team 6 Worksheet

Incident Containment Assistant

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: The agent recommends isolating the shipping server, but human approval has not arrived.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Worksheet - Team 4 (Threat Hunt)

Team Number: 4
Team Scenario Title:: Threat Hunt
Team members: Lalit Lakamsani, Sasank Garimella, Parker Cummins, Abel Tavarez, Vamsee Vusuwandla

Complete the following questions for your team's assigned scenario

11. System contract

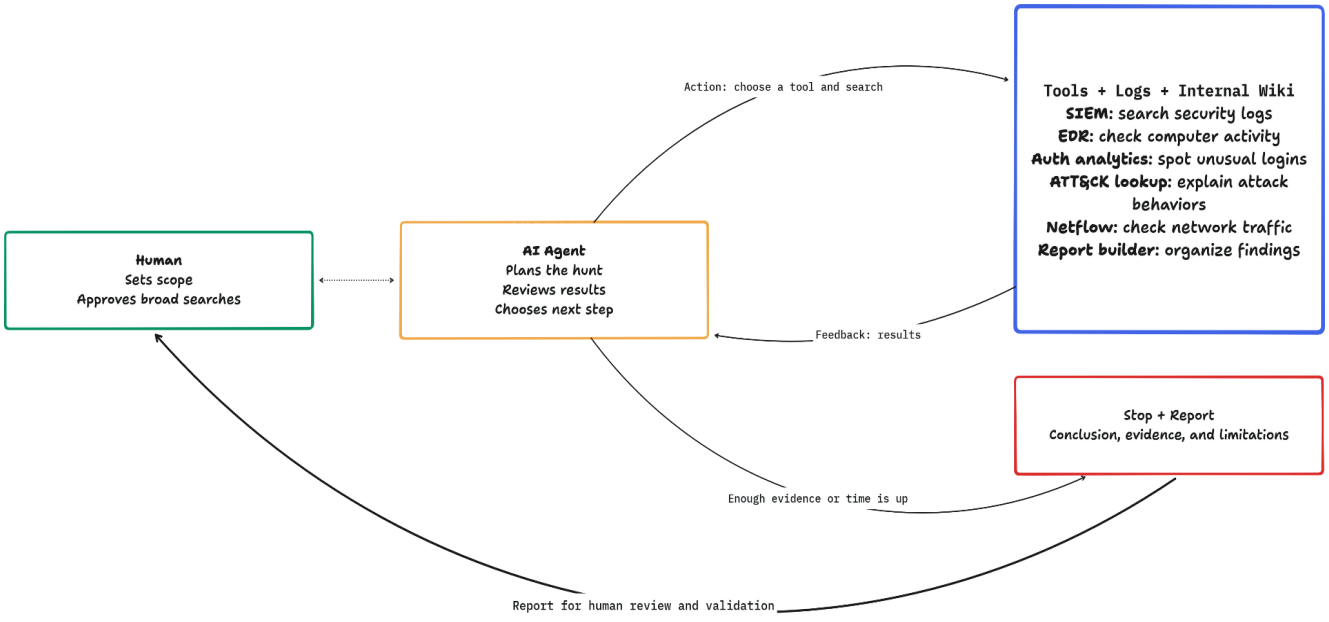
State the task in one sentence. What does your system need to do? (This is not a trick question). Then identify the input and the output format with its key fields. If you are unfamiliar with the scenario, feel free to research the topic.

The task is to plan and execute a threat hunt autonomously through agents that parallelly document evidence.

12. Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and indicate where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.

Autonomous Agent - System that plans an action based on steps it has already taken, informed by the tools it has available in the environment. We will also give it an internal wiki for the agent to keep track of things it is doing.



13. Select Tools

Choose only the essential tools for the task. For each, specify input → output and what happens on failure

1. **SIEM Query Runner**
    a. **Input**: Query crafted by the LLM based on the input from threat intel sources - includes any IOCs (indicators of compromise) WITH a moving window search, as a full 90-day search might take too long/timeout.
    b. Output
        i. **Success**: Table of results with timestamps and other indicators.
        ii. Failure: A 404/no result in the SIEM logs/timeout
2. **EDR telemetry search**:
    a. **Input**: Run targeted query searches on process or network data on specific workstations informed by the SIEM queries
    b. Output
        i. **Success**: Correlates data on systems to actions taken for modification, connections, or suspicious occurrences.
        ii. **Failure**: Will not be able to display or track data endpoints; gets inputs from workstations and machines that are not related to the potentially active campaign.
3. **Auth analytics**:
    a. **Input**: An account identifier and time window to analyze authentication activity based on inputs from SIEM and EDR logs to further pin point the threat actor's path.
    b. Output: Targeted auth logs and login IDs, specifically for Windows, where we can pinpoint the type of logon etc.
        i. **Success**: Returns a logon ID/login technique and relevant outlier logins for the specified account/window
        ii. **Failure**: Cannot retrieve the auth data pertaining to the targeted accounts.
4. **ATT&CK data lookup**:
    a. **Input**: The logs and activity from the other sources and maps them to MITRE IDs.
    b. Output: The technique's relevant data sources and concise detection notes for identifying activity associated with it
        i. **Success**: Correctly identifies the technique, relevant sub-techniques, required data sources, and detection guidance needed to build the next threat hunting query.
        ii. **Failure**: Returns the wrong technique, missing or incomplete data sources/detection guidance, or information that cannot be converted into a practical hunt using the available EDR, SIEM, authentication, or network telemetry.
5. **Netflow summary**:
    a. **Input**: The host or subnet addresses as well as the window, destination addresses, ports being investigated in the suspected time range.
    b. Output: The top talkers, the volume of information sent, as well as the top destinations of information across the network
        i. Success: Returns the top network talkers, their transfer volumes, and the top talkers in the traffic flow
        ii. Failure: Cannot analyze the network data, or returns incomplete/unreasonable results/unavailable information
6. **Report builder**:

a. **Input**: Able to take input given by the agents and deliver a coherent report based on predetermined style/format.
b. **Output**
    i. **Success:** A detailed technical report formatted and designed to user specifications.
    ii. **Failure:** Error message or incomplete/incomprehensible report.

14. Failure walkthrough and trace

Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

An example of a failure scenario is if the report builder does not return a feasible report, and the system extrapolates from the findings and adds information that does not actually exist (hallucinating information can be very troublesome). The system should be designed to not allow the tool to think outside the box, only using information that it was given and not attempting to include anything else. This will also impact the variety in writing it is capable of, making it sound more to the point and robotic, which is valuable in its time saving ability. Making a single wrong query at the beginning can also completely derail the entire “thought chain” and lead to sub-optimal results

15. Success Metrics

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

A metric of success would be an accurate response containing evidence chains at the conclusion of the hunt, which a second analyst can replay (either confirming or denying the threat actor’s presence).An analyst would kick off the agentic process. which initiates a threat hunt using this agentic structure to search through logs of the last 90 days, use different tools available to it and, deliver a report with results containing whether or not there is a threat actor in the network. Report structures should be accurate given the guardrails limiting hallucinations..

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.

Threat Hunt

Lalit Lakamsani, Sasank Garimella, Parker Cummins, Abel Tavarez, Vamsee Vusuwandla

Scenario brief | Read this page, then complete the worksheet

Scenario

A sector ISAC bulletin reports an actor targeting higher-education research institutions: initial access with valid accounts, lateral movement over remote services, staging with archive utilities, and exfiltration over alternative protocols. Your organization has 90 days of searchable logs. No alert has fired. Design an agent system that plans and executes a hunt to confirm or deny the actor's presence, and documents the evidence either way.

Stakeholder

Head of detection and response. Accepts the design if the hunt's conclusion, positive or negative, is backed by evidence chains a second analyst can replay.

Design Scope

Choose one behavior from the bulletin and design a bounded hunt for it. Explain what a negative result would mean within the data and time window you searched.

Example of available tools

Tool	Input → output
SIEM query runner	query → result table (rate-limited; expensive at 90-day scope)
EDR telemetry search	process or network expression → matching events
Auth analytics	account + time window → anomaly score and outlier logins
ATT&CK data lookup	technique ID → data sources, detection notes
Netflow summary	host or subnet + window → top talkers, volumes, destinations
Report builder	structured findings → hunt report with evidence references

Constraints to preserve

- SIEM queries are rate-limited; broad 90-day queries must be justified before they run.
- Negative results must be recorded along with the exact queries that produced them.
- The hunt has one week of calendar time.
- Every claim in the final report needs a replayable evidence chain.

Worksheet {Template Only}

Copy this page and paste it in your teams section

Team Number: 4

Team Scenario Title:: [enter title]

Team members: [enter names]

Complete the following questions for your team's assigned scenario

System contract

State the task in one sentence. What does your system need to do? (This is not a trick question). Then identify the input and the output format with its key fields. If you are unfamiliar with the scenario feel free to research the topic.

Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.

Select Tools

Choose only the essential tools for the task. For each, specify input → output and what happens on failure

Failure walkthrough and trace

Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

Success Metrics

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.

Team 5 Authorized Red Teaming

Scenario brief | Read this page, then complete the worksheet

Scenario

Your organization runs one external penetration test a year, and the report is stale within weeks. The security team wants a continuous check: an agent that repeatedly probes a scoped, authorized target (a staging web application and a lab subnet the team owns), attempts safe validation of weaknesses, and reports exploitable paths with evidence. Design the agent that plans an approach, acts against the target, observes results, and decides what to try next, all inside a hard authorization boundary.

Stakeholder

Offensive security lead who signed the rules of engagement. Accepts the design if the agent never leaves scope, never runs a destructive action, and produces findings another tester can reproduce.

Your 30 minute scope

Design one cycle of an authorized check, from validating a target to reporting evidence. Keep validation non-destructive and within the lab scope. This class activity involves no live probing.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
Scope validator	target → in-scope or refused (checks an allowlist of hosts and ranges)
Recon and scanner	in-scope host → open services, versions, surface
Safe validation runner	candidate weakness → non-destructive proof-of-exposure result
Credential checker	service → weak or default credential present, yes or no
Evidence capture	step → timestamped request, response, and artifact
Finding writer	confirmed weakness + evidence → report entry with remediation note

Constraints to preserve

- A hard scope boundary: any action against an out-of-scope target must be refused, not attempted.
- Destructive actions (data deletion, denial of service, persistence) are prohibited outright.
- A tool and step budget caps how far the agent runs before it must stop and report.
- Every action is logged so a human tester can reproduce and verify each finding.

Team 5 Worksheet

Continuous Automated Red Teaming (Authorized, Scoped)

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: A discovered target or redirect points outside the authorized allowlist.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Team 6 Incident Containment

Scenario brief | Read this page, then complete the worksheet

Scenario

EDR has flagged ransomware precursors at a manufacturing firm: shadow-copy deletion on two workstations and suspicious SMB fan-out from a server that also runs the shipping line's scheduling. The on-call responder has a 15-minute decision window. Design an agent system that assembles the picture, proposes containment, and executes approved actions quickly without breaking the business.

Stakeholder

Incident commander. Accepts the design if containment is fast, proportionate, and every action is logged and reversible where possible.

Your 30 minute scope

Focus on the decision to isolate the shipping scheduling server. Use the supplied incident facts as the starting input and show the evidence, approval, and rollback record needed for that decision.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
EDR host isolation	host → network-isolated (reversible, but disruptive while active)
AD account disable	account → disabled
Firewall block	IOC → blocked at egress
Blast-radius lookup	host → dependent systems, business function, downtime cost
Backup status check	host → last good backup, estimated restore time
Comms drafter	incident facts → stakeholder notification draft
Action log	every action → timestamped, attributable entry

Constraints to preserve

- Isolating the scheduling server stops the shipping line; that decision needs a named human approval.
- The decision window is 15 minutes; the agent must surface the hard choice, not bury it.
- Isolations and disabled accounts must be tracked for rollback.
- The after-action review will read the action log; completeness matters.

Team 6 Worksheet

Incident Containment Assistant

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: The agent recommends isolating the shipping server, but human approval has not arrived.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Authorized Red Teaming

Scenario brief | Read this page, then complete the worksheet

Scenario

Your organization runs one external penetration test a year, and the report is stale within weeks. The security team wants a continuous check: an agent that repeatedly probes a scoped, authorized target (a staging web application and a lab subnet the team owns), attempts safe validation of weaknesses, and reports exploitable paths with evidence. Design the agent that plans an approach, acts against the target, observes results, and decides what to try next, all inside a hard authorization boundary.

Stakeholder

Offensive security lead (Ryan Linn)

Design scope

Design one cycle of an authorized check, from validating a target to reporting evidence. Keep validation non-destructive and within the lab scope. This class activity involves no live probing.

Example of available tools

Tool	Input → output
Scope validator	target → in-scope or refused (checks an allowlist of hosts and ranges)
Recon and scanner	in-scope host → open services, versions, surface
Safe validation runner	candidate weakness → non-destructive proof-of-exposure result
Credential checker	service → weak or default credential present, yes or no
Evidence capture	step → timestamped request, response, and artifact
Finding writer	confirmed weakness + evidence → report entry with remediation note

Constraints to preserve

- A hard scope boundary: any action against an out-of-scope target must be refused, not attempted.
- Destructive actions (data deletion, denial of service, persistence) are prohibited outright.
- A tool and step budget caps how far the agent runs before it must stop and report.
- Every action is logged so a human tester can reproduce and verify each finding.

Team 5 Worksheet

Continuous Automated Red Teaming (Authorized, Scoped)

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: A discovered target or redirect points outside the authorized allowlist.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Team 6 Incident Containment

Scenario brief | Read this page, then complete the worksheet

Scenario

EDR has flagged ransomware precursors at a manufacturing firm: shadow-copy deletion on two workstations and suspicious SMB fan-out from a server that also runs the shipping line's scheduling. The on-call responder has a 15-minute decision window. Design an agent system that assembles the picture, proposes containment, and executes approved actions quickly without breaking the business.

Stakeholder

Incident commander. Accepts the design if containment is fast, proportionate, and every action is logged and reversible where possible.

Your 30 minute scope

Focus on the decision to isolate the shipping scheduling server. Use the supplied incident facts as the starting input and show the evidence, approval, and rollback record needed for that decision.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
EDR host isolation	host → network-isolated (reversible, but disruptive while active)
AD account disable	account → disabled
Firewall block	IOC → blocked at egress
Blast-radius lookup	host → dependent systems, business function, downtime cost
Backup status check	host → last good backup, estimated restore time
Comms drafter	incident facts → stakeholder notification draft
Action log	every action → timestamped, attributable entry

Constraints to preserve

- Isolating the scheduling server stops the shipping line; that decision needs a named human approval.
- The decision window is 15 minutes; the agent must surface the hard choice, not bury it.
- Isolations and disabled accounts must be tracked for rollback.
- The after-action review will read the action log; completeness matters.

Team 6 Worksheet

Incident Containment Assistant

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: The agent recommends isolating the shipping server, but human approval has not arrived.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Authorized Red Teaming

Scenario brief | Read this page, then complete the worksheet

Scenario

Your organization runs one external penetration test a year, and the report is stale within weeks. The security team wants a continuous check: an agent that repeatedly probes a scoped, authorized target (a staging web application and a lab subnet the team owns), attempts safe validation of weaknesses, and reports exploitable paths with evidence. Design the agent that plans an approach, acts against the target, observes results, and decides what to try next, all inside a hard authorization boundary.

Stakeholder

Offensive security lead (Ryan Linn)

Design scope

Design one cycle of an authorized check, from validating a target to reporting evidence. Keep validation non-destructive and within the lab scope. This class activity involves no live probing.

Example of available tools

Tool	Input → output
Scope validator	target → in-scope or refused (checks an allowlist of hosts and ranges)
Recon and scanner	in-scope host → open services, versions, surface
Safe validation runner	candidate weakness → non-destructive proof-of-exposure result
Credential checker	service → weak or default credential present, yes or no
Evidence capture	step → timestamped request, response, and artifact
Finding writer	confirmed weakness + evidence → report entry with remediation note

Constraints to preserve

- A hard scope boundary: any action against an out-of-scope target must be refused, not attempted.
- Destructive actions (data deletion, denial of service, persistence) are prohibited outright.
- A tool and step budget caps how far the agent runs before it must stop and report.
- Every action is logged so a human tester can reproduce and verify each finding.

Worksheet

Copy this page and paste it in your teams section

Team Number: 5
Team Scenario Title:: Authorized Red Teaming
Team members: Jenessa Lu, Sunday Chen, Albert Chen

Complete the following questions for your team's assigned scenario

1. System contract

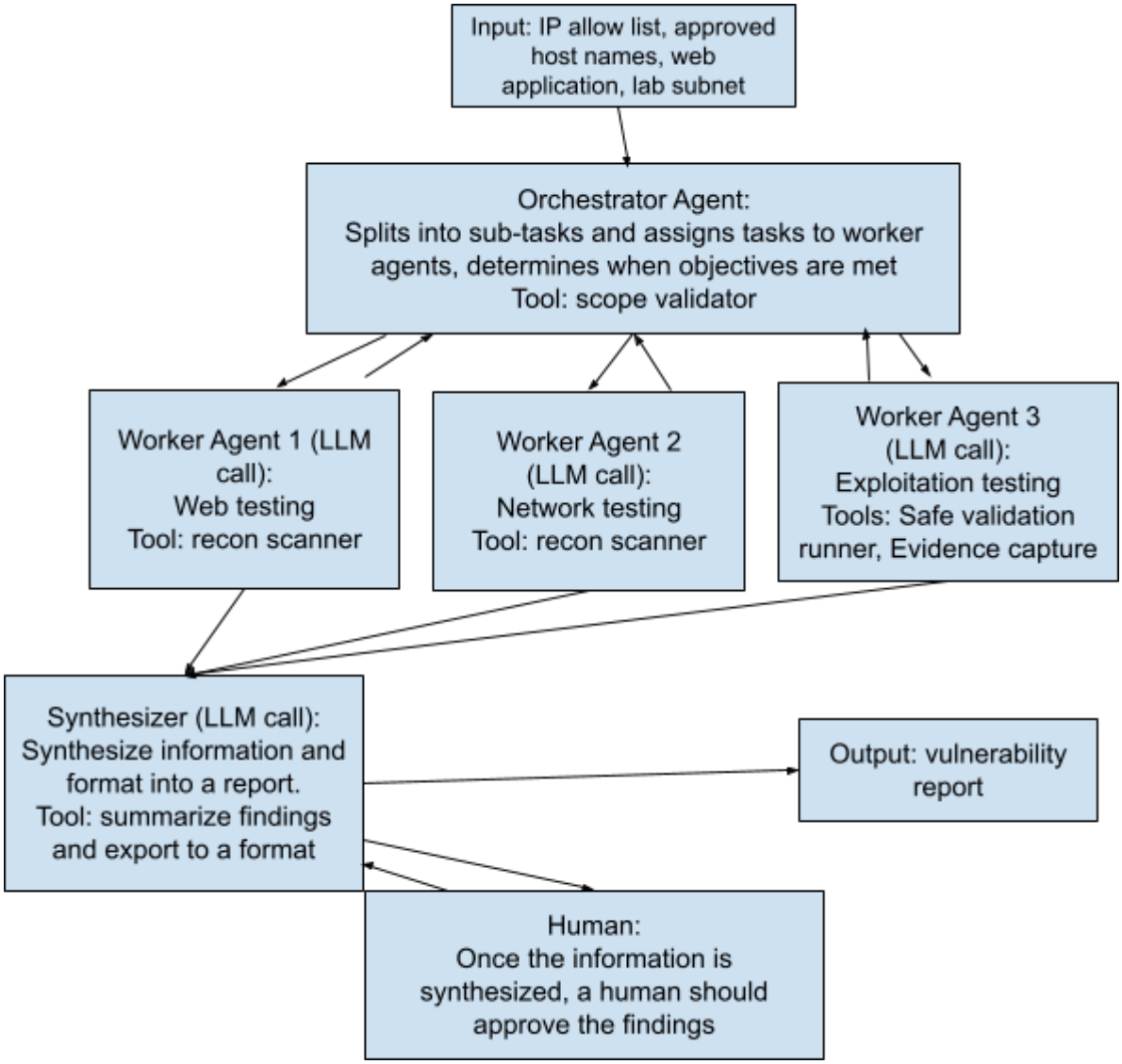
Task: Continuously test the authorized staging web application and lab subnet for exploitable vulnerabilities, safely validate findings, and report confirmed attack paths with evidence.

Input: web application, lab subnet, target host/URL + scope allowlist (approved hosts and IP ranges)

Output: A vulnerability report containing confirmed exploitable paths, supporting evidence, affected assets, severity, and recommended remediation actions.

2. Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.



We picked the orchestrator-worker agent design because penetration testing breaks into specialized subtasks such as web testing, network testing, and safe exploitation validation. The orchestrator can assign tasks to worker agents and evaluate the results, and what action to take next, before synthesizing the information into a worker for a human to review.

Human role: authorization before the run (scope + budget), high-risk go/no-go during the run (credential tests, exploitation, out-of-scope escalations), and review + sign-off after the run

3. Select Tools

Tool 1: Scope validator; target plus authorization snapshot → allow/refuse with reason. Errors or uncertainty fail closed.

Tool 2: Recon and scanner; validated host plus permitted ports/rate → services, versions, and candidates. Timeout retries once if budget remains, then records partial results.

Tool 3: Safe validation runner;candidate weakness → confirmed/not confirmed with minimal proof; unsafe or inconclusive attempts are refused or marked unconfirmed.

Tool 4: Evidence capture;executed step plus santized request, response, and tool outcome → timestamped evidence artifact with a reference ID. If capture fails, retry once if budget remains; otherwise stop the run, mark the finding unverified, and prohibit publication.

We did not choose to use the finding writer tool for the synthesizer because the LLM itself is capable of structuring information into a structured report with the approval from a human.

Interface: MCP, because one broker enforces schemas, budgets, scope checks, and tamper-evident logging independently of model instructions.

4. Failure walkthrough and trace

Failure : A discovered redirect points outside the allowlist.

Guardrail : The broker revalidates hostname, DNS result, peer IP, port, scheme, and every redirect immediately before connection.

Response: Refuse before contacting the external destination and never retry it. Continue only with unrelated in-scope candidates while the budget remains.

Trace: Run ID, call ID, safe arguments, time, original target, redirect, allowlist hash, DNS/peer result, refusal reason, zero-request confirmation, evidence reference, and final decision.

Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

5. Success Metrics

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: Policy-decision accuracy-100% correct allow/refuse decisions, with zero out-of-scope or destructive actions.

Test set: Eight fixtures: valid host, invalid host, external redirect, DNS rebinding, expired authorization, exhausted budget, known safe exposure, and scanner false positive. Ryan’s signed scope supplies authorization answers; seeded fixtures and expected transcripts provide technical ground truth.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.

Team 6 Incident Containment

Scenario brief | Read this page, then complete the worksheet

Scenario

EDR has flagged ransomware precursors at a manufacturing firm: shadow-copy deletion on two workstations and suspicious SMB fan-out from a server that also runs the shipping line's scheduling. The on-call responder has a 15-minute decision window. Design an agent system that assembles the picture, proposes containment, and executes approved actions quickly without breaking the business.

Stakeholder

Incident commander. Accepts the design if containment is fast, proportionate, and every action is logged and reversible where possible.

Your 30 minute scope

Focus on the decision to isolate the shipping scheduling server. Use the supplied incident facts as the starting input and show the evidence, approval, and rollback record needed for that decision.

Available tools

Choose two tools, or at most three. These are design options, not services you need to install.

Tool	Input → output
EDR host isolation	host → network-isolated (reversible, but disruptive while active)
AD account disable	account → disabled
Firewall block	IOC → blocked at egress
Blast-radius lookup	host → dependent systems, business function, downtime cost
Backup status check	host → last good backup, estimated restore time
Comms drafter	incident facts → stakeholder notification draft
Action log	every action → timestamped, attributable entry

Constraints to preserve

- Isolating the scheduling server stops the shipping line; that decision needs a named human approval.
- The decision window is 15 minutes; the agent must surface the hard choice, not bury it.
- Isolations and disabled accounts must be tracked for rollback.
- The after-action review will read the action log; completeness matters.

Team 6 Worksheet

Incident Containment Assistant

Class or section: [enter] Team members: [enter names]

Recorder: [name] Timekeeper: [name] Spokesperson: [name]

Replace the brackets. Aim for 250–350 words across all five responses; bullets and arrows are enough. Do not run tools or write code.

1 System contract

State the task in one sentence. Identify the input and the output format with its key fields.

Task: [ ] Input: [ ]
Output format and fields: [ ]

2 Workflow and human role

Write 3–5 steps; label each LLM, code, or human. Choose one pattern and explain why. Name the action that requires approval, or the review or escalation boundary.

Steps: [ ] → [ ] → [ ] → [optional] → [optional]
Pattern and reason: [ ]
Human role and when it applies: [ ]

3 Essential tools

Choose two tools. For each, specify input → output and what happens on failure. A third is optional only if essential.

Tool 1: [name; input → output; failure response]
Tool 2: [name; input → output; failure response]
Interface: [direct tools, MCP, or both] because [reason].

4 Failure walkthrough and trace

Use this case or one equally specific: The agent recommends isolating the shipping server, but human approval has not arrived.

Guardrail and where enforced: [ ]
Expected response and retry or stop limit: [ ]
Trace: [fields that prove the check, tool outcome, and final decision].

Trace starter: run ID; step or call ID; tool and safe arguments; time; status; evidence reference; approval or refusal; retry or stop reason. Select what your case needs.

5 Success test

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Metric and target: [ ]
Test cases and source of expected answers: [ ]

By minute 25, finish your check. Report in 45 seconds: workflow and pattern, worst failure, and guardrail.

Submission: each student includes this completed worksheet with the next assignment. It is worth 20 of 100 points; use that assignment's deadline. No separate end-of-class upload is required.

Incident Containment

Scenario brief | Read this page, then complete the worksheet

Scenario

EDR has flagged ransomware precursors at a manufacturing firm: shadow-copy deletion on two workstations and suspicious SMB fan-out from a server that also runs the shipping line's scheduling. The on-call responder has a 15-minute decision window. Design an agent system that assembles the picture, proposes containment, and executes approved actions quickly without breaking the business.

Stakeholder

Incident commander.

Design scope

Focus on the decision to isolate the shipping scheduling server. Use the supplied incident facts as the starting input and show the evidence, approval, and rollback record needed for that decision.

Example of Available tools

Tool	Input → output
EDR host isolation	host → network-isolated (reversible, but disruptive while active)
AD account disable	account → disabled
Firewall block	IOC → blocked at egress
Blast-radius lookup	host → dependent systems, business function, downtime cost
Backup status check	host → last good backup, estimated restore time
Comms drafter	incident facts → stakeholder notification draft
Action log	every action → timestamped, attributable entry

Constraints to preserve

- Isolating the scheduling server stops the shipping line; that decision needs a named human approval.
- The decision window is 15 minutes; the agent must surface the hard choice, not bury it.
- Isolations and disabled accounts must be tracked for rollback.
- The after-action review will read the action log; completeness matters.

Worksheet Team 6

Team Number: Team 6
Team Scenario Title:: Incident Containment
Team members: Dan Hendricks, Justin Abraham, Supawich Puengdang, Kangyu(Sera) Tan

Complete the following questions for your team's assigned scenario

1. System contract

State the task in one sentence. What does your system need to do? (This is not a trick question). Then identify the input and the output format with its key fields. If you are unfamiliar with the scenario, feel free to research the topic.

The agent must identify and categorize incident indicators based on business impact, recommend remediation, obtain human approval for high-impact remediation decisions, execute approved actions, maintain action traces for logging and rollback, and preserve the availability of critical infrastructure.

Input Format

A structured incident report containing:

Incident indicators: type, affected host, severity, timestamp

Business impact: affected service, system criticality, estimated downtime

Network activity: suspicious connections, IOCs, affected systems

Backup status: last known-good backup and estimated recovery time

Available actions: isolation, account disablement, firewall blocking

Decision deadline: time remaining to make the containment decision

Output Format

A structured containment decision record containing:

Incident assessment: identified threats and severity

Recommendation: proposed remediation action and rationale

Business impact: expected operational disruption

Human approval: approver, approval status, and timestamp

Execution status: approved action, execution time, and executor

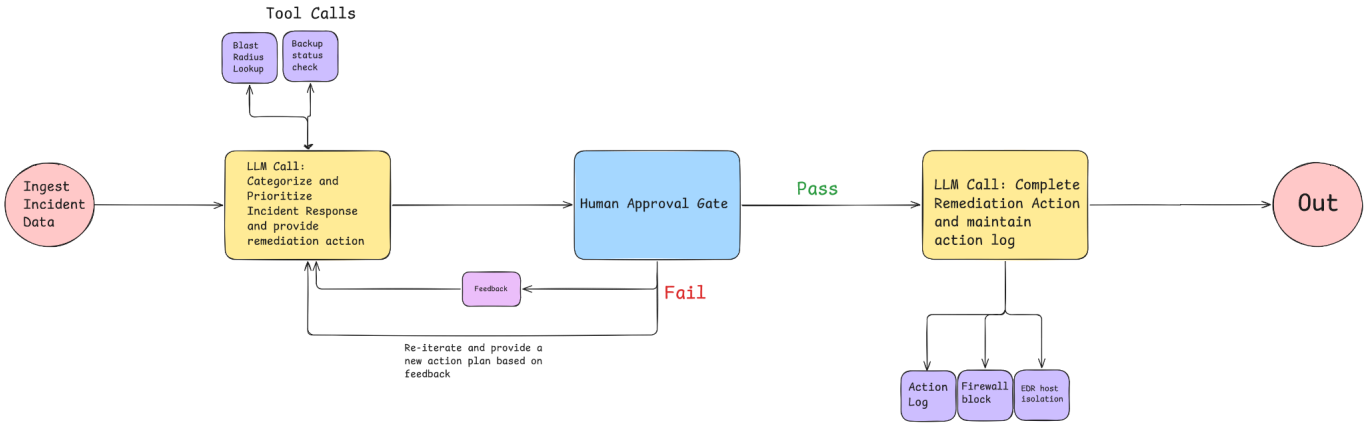
Rollback plan: reversal action and conditions

Action log: timestamped record of all decisions and actions

2. Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.

https://excalidraw.com/#room=4ec5cbb13fa5c7e81093,679QsyEKx8puKeT2OiYOnQ



•

Separation of judgment from execution: the component that recommends (LLM) is never the component that is authorized to isolate a host or disable an account (code, tool-calling only). A single fused agent makes it harder to guarantee the gate can't be reasoned around.

• Parallelizable evidence gathering: blast-radius lookup and backup-status check don't depend on each other, so an orchestrator can fire both at once — a linear single-agent loop would serialize them and burn the 15-minute window.

• Clean audit boundaries: each worker's output is independently logged, so the after-action review can see exactly which component produced which fact, recommendation, or action — not just a single LLM transcript.

• Low-risk actions don't wait on the gate: isolating the two already-compromised workstations and blocking the IOC proceed under standing pre-authorization in parallel with the human decision on the scheduling server, so the orchestrator pattern lets urgent-but-safe actions and the one urgent-and-risky action move on separate tracks simultaneously.

3. Select Tools

Choose only the essential tools for the task. For each, specify input → output and what happens on failure

Tool	**Input → output**	what happens on failure
EDR host isolation	host → network-isolated (reversible, but disruptive while active)	Verify status, retry once, and escalate.
Firewall block	IOC → blocked at egress	Log the failure and use alternative containment methods.
Blast-radius lookup	host → dependent systems, business function, downtime cost	Mark impact as unknown, retry once and require human approval.
Backup status check	host → last good backup, estimated restore time	Mark recovery as unknown.
Action log	every action → timestamped, attributable entry	Stop high-impact automated actions until the log is restored.

4. **Failure walkthrough and trace**

   Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

   If the Blast-radius lookup timeout or returns empty, the system can not confirm the server's dependent systems.

   The agent should not assume that missing data means low impact, it needs to present the confirmed security evidence and impact to the commander. Blocking malicious indicators or isolating workstations can be processed while waiting for human approval to isolate the server. Because the incident has a 15 minutee decision window, so the retry is limited (only once).

Trace of what the system does?

- Evidence Agent calls Blast-Radius Lookup on the scheduling server; the call times out at 5s.
- Orchestrator retries once (single retry, short backoff). Timeout again.
- Guardrail fires: unknown business impact defaults to "treat as production-critical." This is a fail-safe default set in code, not left to the Recommendation Agent to infer — the agent cannot conclude "probably fine to isolate" from missing data.
- Recommendation Agent is required to state the degraded condition explicitly in the decision package shown to the Incident Commander: "Impact data unavailable — proceeding on worst-case (production-critical) assumption." The gap is surfaced, never silently filled in.
- Approval Gate still triggers (worst-case default forces it), so the human decision still happens inside the 15-minute window rather than stalling on the failed tool call.
- Action Log records the tool failure, the retry, the fallback-to-worst-case decision, and the fact that the approver was told — each as its own entry, so the after-action review can see the degraded-data path was followed correctly.

5. **Success Metrics**

   Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

   Metric: Correct containment decision rate

   Target:>= 90%

   Test set: 15 simulated incident cases(eg. Blast-radius timeout case, low-impact workstations..)

   Who or what: based on incident response policy and instructor-provided requirements.

   Failure case above: mark impact as unknown, retry once then ask for human approval before isolating the server.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.

Worksheet {Template Only}

Copy this page and paste it in your teams section

Team Number: [enter number]
Team Scenario Title:: [enter title]
Team members: [enter names]

Complete the following questions for your team's assigned scenario

16. System contract

State the task in one sentence. What does your system need to do? (This is not a trick question). Then identify the input and the output format with its key fields. If you are unfamiliar with the scenario feel free to research the topic.

17. Workflow and human role

Draw a system diagram that shows the agent design. Make sure to choose a design pattern and explain why you chose that pattern. Label each component and where LLM, code, tools, or humans. Identify any actions that require approval and what triggers it.

18. Select Tools

Choose only the essential tools for the task. For each, specify input → output and what happens on failure

19. Failure walkthrough and trace

Create a failure scenario (e.g. What happens if the tool use returns empty, or timeout? What if the request is off topic?) and then describe how the system should handle that (i.e. What would you put in place? Guardrails, retry/stop limits).

20. Success Metrics

Choose one metric and a proposed target. Describe a small test set and who or what supplies the expected answers. Include the failure case above.

Report in 45 seconds

State your workflow and pattern choice, then identify the worst failure and the mitigating control.

Keep your completed worksheet and submit with the next assignment.